

Evaluacion de ADR JWT vs Actividad 3

Validacion de JWT en API Gateway para prevenir token spoofing

1. Checklist de requirements de la actividad

Requerimiento: ADR formato Nygard, una pagina, markdown

[OK] Formato Nygard: titulo, contexto, decision, consecuencias

Tiene todos los elementos: titulo, justificacion, contexto, restricciones, decision, consecuencias (en tabla), conexion con threat model, y pruebas.

[RE] Formato markdown

El ADR esta en .docx. La actividad pide explicitamente 'escrito en markdown, una pagina, que pueda vivir en docs/adr/ del repositorio'.

[OK] Una pagina de extension

El contenido cabe en una pagina en markdown. El .docx actual es de extension adecuada.

Requerimiento: Elegir una de las 5 defensas priorizadas

[OK] Elige validacion JWT en API Gateway

La validacion JWT es una defensa en la capa de autenticacion, que fue parte de la tabla STRIDE construida en sala.

[OK] Justifica si no es la mas votada

Incluye seccion 'Justificacion' que explica por que esta defensa es la mas temprana en la cadena.

Requerimiento: Contexto del problema

[OK] Contexto describe el problema que resuelve

Contexto explica el servicio, los 3 vectores de ataque (alg=none, key confusion, expirado).

[OK] Menciona la(s) amenaza(s) concreta(s) del threat model

Los 3 vectores se vinculan directamente con STRIDE Spoofing y la tabla de amenazas.

Requerimiento: Decision corta y verificable

[OK] Decision en 1-2 frases traducibles a codigo

Decision clara: usar RS256/ES256, JWKS, cache local TTL. Incluye config minima obligatoria con 5 parametros.

[OK] Configuracion concreta incluida

algorithms_allowed, verify_exp, jwks_uri, jwks_cache_ttl_seconds, reject_algorithms.

Requerimiento: Consecuencias balanceadas (>=2 +, >=2 -)

[OK] Tiene consecuencias positivas

Tabla incluye 4 positivas: elimina ataques alg=none, rotacion JWKS, limita dano de credenciales robadas, cobertura testeable.

[OK] Tiene consecuencias negativas

Tabla incluye 4 negativas: latencia, complejidad operacional, ventana de revocacion, riesgo de config erronea.

[OK] Consecuencias balanceadas

4 positivas vs 4 negativas. Cada par positivo/negativo esta alineado al mismo tema.

Requerimiento: Conexion con el threat model

[OK] Referencia explicita a fila de la tabla amenaza->control

Cita: 'Componente: API Gateway | STRIDE: Spoofing | OWASP LLM: LLM06 | Riesgo: Alto'.

[OK] Pruebas de aceptacion incluidas

3 pruebas concretas con curl: alg=none -> 401, expirado -> 401, RS256 valido -> 200.

2. Observaciones detalladas

Fortalezas del ADR

- La justificación inicial es sólida: conecta por que esta defensa es la mas temprana en la cadena y por que invalidar autenticación rompe todo el modelo de confianza.
- La tabla de consecuencias es el punto mas fuerte: 4 pares (+ / -) alineados por tema (ataques, rotación, expiración, testeabilidad). Muestra comprensión real del trade-off.
- La configuración mínima obligatoria es excelente: 5 parametros concretos que cualquier developer puede copiar a código.
- Buenos vectores de ataque cubiertos: alg=none, HS256 key confusion, expirado. Son los 3 clásicos de JWT.

Debilidades

- Formato .docx en vez de markdown. La actividad pide 'markdown, una pagina, que pueda vivir en docs/adr/ del repositorio'. Convierte a .md antes de entregar.
- Falta status del ADR (propuesto/aceptado/superado). El formato Nygard estandar incluye status y fecha.
- Falta numero de ADR (ADR-001, ADR-002...). La actividad menciona 'docs/adr/' como directorio, lo que sugiere numeración secuencial.
- La conexión con OWASP LLM06 es debatible. El riesgo principal de un JWT falsificado es acceso a datos de otros usuarios (LLM02 - Sensitive Information Disclosure). LLM06 es Excessive Agency, que es un problema de autorización, no de autenticación.

Pruebas faltantes sugeridas

- Token con algoritmo HS256 firmado con clave pública (key confusion) -> 401
- Token con audiencia (aud) incorrecta -> 401
- Solicitud sin token Authorization -> 401
- Token con payload JWT de tamaño excesivo -> 413
- Token con scope que no corresponde al endpoint -> 403

Sugerencias de mejora

- Convierte el ADR a markdown (.md) para que pueda vivir en docs/adr/ del repo.
- Agrega un numero de ADR y estado (p.ej., 'ADR-007 | Status: Accepted | 2026-05-06').
- Considera agregar una prueba mas para key confusion (HS256).
- La conexión con OWASP podría mencionar también LLM02 como riesgo secundario.
- Agrega citation grounding para cada afirmación de la tabla de amenazas.

3. Nota estimada sobre la actividad

Nota: 6.0 / 7.0

Formato ADR (Nygard)	1.0/1.0	Titulo, contexto, decision, consecuencias, conexion
Formato markdown	0.0/0.5	Entregado en .docx, no markdown
Contexto y amenazas	1.0/1.0	3 vectores JWT bien descritos
Decision verificable	1.0/1.0	Config concreta con 5 parametros
Consecuencias	1.5/1.5	4 pares +/-, balanceados y alineados
Conexion threat model	1.0/1.0	Fila explicita + pruebas de aceptacion
Numeracion y estado	0.0/0.5	Falta ADR-NNN y status
Precision OWASP	0.5/0.5	LLM06 es aceptable, podria mejorar

Total: 6.0 / 7.0

Comentario: El ADR es solido. La parte conceptual (contexto, consecuencias, decision) esta muy bien trabajada. El unico punto que descuenta es el formato de entrega (.docx en vez de .md) y la falta de numero/status. La tabla de consecuencias es el punto mas destacable: 4 pares +/- perfectamente alineados muestran que entendiste el trade-off.